

Strengths:

- **Comprehensive Coverage:** It's clear that you've covered all the key features of an authentication system, which is vital for ensuring users are properly authenticated and secure.
- **Security Focus:** Your attention to password hashing, encryption, and token-based authentication shows a solid understanding of security best practices.
- **Logical Flow:** The authentication process is well-structured, which will make it easier to follow and maintain over time.
- **User Privacy:** Prioritizing users data privacy is essential, and it's great to see that you're keeping it top of mind for your system.

Areas for Improvement:

- **Readability & Clarity**
 - Error handling feedback, personalized error messages can significantly improve users experience. Instead of generic responses like "Invalid credentials," consider messages such as "Incorrect password", " Please try again" or "reset your password" after multiple wrong attempts.
 - The user role distinction is a great suggestion. For systems with multiple roles, defining clear access levels makes maintenance easier and helps avoid permission issues.
- **Security Best Practices:**
 - **Password Recovery System:** Implementing a secure way for users to recover their accounts, such as a "Forgot Password" or "Reset Password" feature, is essential.
 - **Rate Limiting:** To prevent brute-force attacks, consider implementing rate limiting on authentication attempts.
 - **Session Management:** Ensure that user sessions expire after a period of inactivity and provide an option to log out from all devices. This reduces the risk of unauthorized access.

- **Additional Security Features:**
 - **Multi-Factor Authentication (MFA):** Adding an extra layer of security with MFA (e.g., email or SMS verification) will further protect against unauthorized access.
 - **Account Locking Mechanism:** Temporarily locking accounts after multiple failed login attempts adds another layer of defense against potential attacks.

Overall Feedback & Suggestions for Improvement:

- **Clarify User Roles:** Clearly define user roles to improve access control and make the system easier to manage. This distinction will help ensure the authentication system is well-structured and permissions are handled correctly.
- **Improve Error Handling:** Provide more detailed and user-friendly error messages, especially for login failures, incorrect credentials, and session expirations. Instead of generic messages like "Invalid credentials," consider specific feedback such as "Incorrect password. Try again or reset your password." This will improve user experience and help users troubleshoot issues more effectively.
- **Enhance Security Features:**
 - **Password Recovery:** Implement a "Forgot Password" or "Reset Password" functionality to help users recover their accounts securely. This is crucial for improving usability and ensuring access.
 - **Multi-Factor Authentication (MFA):** Adding an extra layer of security with MFA (e.g., email or SMS verification) will strengthen the protection against unauthorized access.
 - **Session Management:** Implement session expiry after a certain period of inactivity and provide an option to log out from all devices. This will reduce the risk of unauthorized access and improve overall security.
 - **Rate Limiting:** Consider implementing rate limiting on authentication requests to prevent brute-force attacks, further enhancing security.